

The Promise vs. Reality of NFT Decentralization: An Empirical Study of Storage Strategies and Defects

Yufang Wu
Beijing Jiaotong University
Beijing, China
wu.yufang@bjtu.edu.cn

Siwen Chen
Beijing Jiaotong University
Beijing, China
24125214@bjtu.edu.cn

Chao Li*
Beijing Jiaotong University
Beijing, China
Beijing Advanced Innovation Center
for Future Blockchain and Privacy
Computing
Beijing, China
li.chao@bjtu.edu.cn

Yuan Weng
Beijing Jiaotong University
Beijing, China
yuan.weng@bjtu.edu.cn

Wei Wang*
Xi'an Jiaotong University
Xi'an, Shaanxi, China
Beijing Jiaotong University
Beijing, China
wei.wang@xjtu.edu.cn

Abstract

The value of NFTs (Non-Fungible Tokens) is built on the promise of decentralization, permanence, and immutability. However, a significant gap exists between this perception and reality. In this paper, we collect over 16 million real-world NFTs and systematically analyze their storage locations. Our results reveal a widespread reliance on fragile off-chain storage and uncover a "Blue-chip Trap" where high-value assets depend heavily on centralized infrastructure, rendering the promise of decentralization largely misleading. Consequently, we propose the first taxonomy of NFT storage defects, classifying eight distinct vulnerabilities into access failure, tamperability, and forgeability. Through a large-scale empirical analysis, we map real-world assets to this taxonomy, confirming the widespread prevalence of these defects across the ecosystem. Finally, we analyze the impact of these defects on assets, users, and the ecosystem, and systematically quantify their severity using the Common Vulnerability Scoring System (CVSS). Our assessment reveals that all identified defects pose substantial risks, providing a reference for developers to design more secure storage strategies.

CCS Concepts

• Security and privacy → Digital rights management.

Keywords

Blockchain, NFT, Defects, Storage

*Corresponding authors: Chao Li and Wei Wang.



This work is licensed under a Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 International License.
WWW '26, Dubai, United Arab Emirates
© 2026 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-2307-0/2026/04
<https://doi.org/10.1145/3774904.3792338>

ACM Reference Format:

Yufang Wu, Siwen Chen, Chao Li, Yuan Weng, and Wei Wang. 2026. The Promise vs. Reality of NFT Decentralization: An Empirical Study of Storage Strategies and Defects. In *Proceedings of the ACM Web Conference 2026 (WWW '26)*, April 13–17, 2026, Dubai, United Arab Emirates. ACM, New York, NY, USA, 12 pages. <https://doi.org/10.1145/3774904.3792338>

1 Introduction

In recent years, Non-Fungible Tokens (NFTs) have grown from a specialized concept into a multi-billion-dollar global market, significantly impacting the digital art, social and gaming domains [25]. NFTs are unique digital certificates, recorded on a blockchain, that represent ownership of an asset. Essentially, the value of NFTs is tied to the permanence and immutability promised by the blockchain, as these characteristics create a verifiable record of ownership that allows them to be traded.

However, a significant gap exists between this promise and the reality of how most NFTs are stored. Contrary to what many believe, the vast majority of NFTs store their actual digital files off-chain. The on-chain token often works only as a pointer to the file, which is hosted on various external systems, from centralized servers (e.g., Amazon AWS [1], Google Cloud [16]) to decentralized networks (e.g., IPFS [17], Arweave [2]). This design creates a fragile dependence on these external systems and introduces serious risks, directly contradicting the promise of blockchain permanence and immutability. These risks are not just theoretical, they have already caused major financial losses. For instance, more than 19,000 images from Nike's valuable "CloneX" NFT collection suddenly disappeared from all major marketplaces due to server failure [11]. A landmark study of more than 46 million Ethereum NFTs found that 12.8% of all metadata, which is the file that describes an asset's properties and links to the actual image, was already lost, representing a value of \$345 million [22].

Despite the severity of these incidents, there is still a lack of systematic understanding of the vulnerabilities inherent in current NFT storage strategy. To address this gap, this paper presents a

comprehensive, data-driven analysis of the NFT storage strategy. To guide our research, we pose the following key questions: **RQ1** *What are the real-world storage strategies of the NFT ecosystem, and how does the choice of storage strategy correlate with asset value?* **RQ2** *What specific storage defects are induced by these strategies, and how prevalent are they in the wild?* **RQ3** *What are the impacts of NFTs storage defects?*

To address these questions, first, we conduct a large-scale empirical study on over 16 million NFTs to quantify real-world storage strategies and their correlation with asset value (RQ1). Second, we propose a taxonomy of eight defects and verify their real-world prevalence (RQ2). Finally, we introduce an assessment framework to evaluate the impact of these defects and quantify their severity with Common Vulnerability Scoring System (CVSS) [15] (RQ3).

In summary, our contributions are as follows:

- We explicitly quantify the storage strategies of over 16 million NFTs, revealing that only 0.08% of images are stored on-chain. Crucially, we reveal a counter-intuitive "Blue-chip Trap" where high-value assets paradoxically exhibit a higher dependency on centralized storage than low-value ones.
- We propose the first taxonomy categorizing eight distinct storage vulnerabilities across three dimensions, and map real-world assets to this taxonomy, confirming the widespread prevalence of these defects across the ecosystem.
- We introduce an assessment framework to evaluate the impact of these defects and quantify their severity with CVSS. We have open-sourced our curated dataset, <https://doi.org/10.5281/zenodo.17277607>, which is the largest of its kind, to facilitate reproducibility and further empirical analysis.

2 Background

2.1 Non-Fungible Token

Non-Fungible Token (NFT) is a blockchain-based record of ownership whose value is rooted in the promise of decentralization and persistence. By using smart contracts, NFTs provide an immutable and publicly verifiable certificate for digital assets [18]. In theory, this on-chain record ensures traceable provenance, thereby offering tamper-proofing and forgery-proofing. Platforms like OpenSea [24] and Rarible [26] have fueled explosive growth in the NFT market, with digital art and collectibles emerging as the most significant applications [10].

Our study focuses on the two dominant Ethereum standards: ERC-721 [13] (for unique assets) and ERC-1155 [12] (for mixed fungibility). While differing in structure, both standards rely on a *tokenURI* to point to off-chain metadata [20], which serves as the primary surface for the storage defects analyzed in this paper.

2.2 NFT Storage Strategy

Based on the location, NFT storage strategies are primarily divided into two main categories: on-chain and off-chain storage strategies.

On-chain storage involves recording all of an NFT's data, including its metadata and the digital asset, directly on the blockchain. As shown in Figure 1, the behavior of the *tokenURI()* function returns a base64-encoded string that directly represents the digital asset itself.

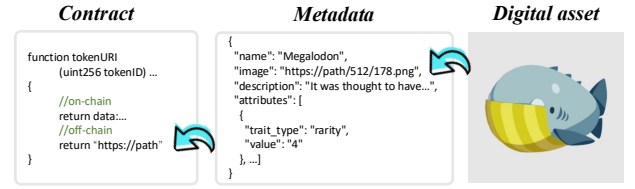


Figure 1: Example for an NFT strategy.

This storage strategy maximizes decentralization and persistence. In contrast, off-chain storage creates a chain of pointers to link the on-chain token to its off-chain files, as illustrated in Figure 1. The *tokenURI()* function in a smart contract returns a URL pointing to an off-chain metadata file. This file, usually a JSON object, contains the asset's properties, such as its name, description, and attributes, and includes a second pointer, the *image_url*, which in turn points to the location of digital asset. Off-chain storage can be further subdivided into two types, i.e., centralized and decentralized storage. Centralized storage is represented by traditional cloud services such as Amazon S3 [1] and Google Cloud Storage [16]. Decentralized storage, such as the InterPlanetary File System (IPFS) [17] and Arweave [2], employ different persistence strategies. While IPFS uses content-addressing to ensure data integrity, its persistence relies on voluntary "pinning" by nodes. In contrast, Arweave offers a "pay-once, store-forever" model, providing a stronger persistence guarantee for digital assets.

3 RQ1: The Reality of NFT Storage

3.1 Data Collection & Classification

To construct our dataset, we collected on-chain transaction data from Ethereum, selected for its status as the largest and most active NFT ecosystem. To ensure a comprehensive and current market representation, our data gathering spanned a 15-month period from January 1, 2024, to March 31, 2025. Our collection process involved a three-step pipeline.

Table 1: Overall NFT data collection

Data	Count
Transactions	82,289,058
Token	16,538,984
Contracts	107,194
NFTs	16,033,207
Metadata_url	13,565,811
Image_url	14,044,196

First, we retrieved the contract address and tokenId from transaction records by querying the standard *eth_getLogs* interface through the Chainstack API [6]. We then deduplicated records based on a unique identifier combination (i.e., contract address and tokenId) to ensure each NFT was represented only once. Finally, we utilized the OpenSea API [23] to obtain the *metadata_url* and *image_url* for each NFT, culminating in a final dataset of 16,033,207 NFTs.

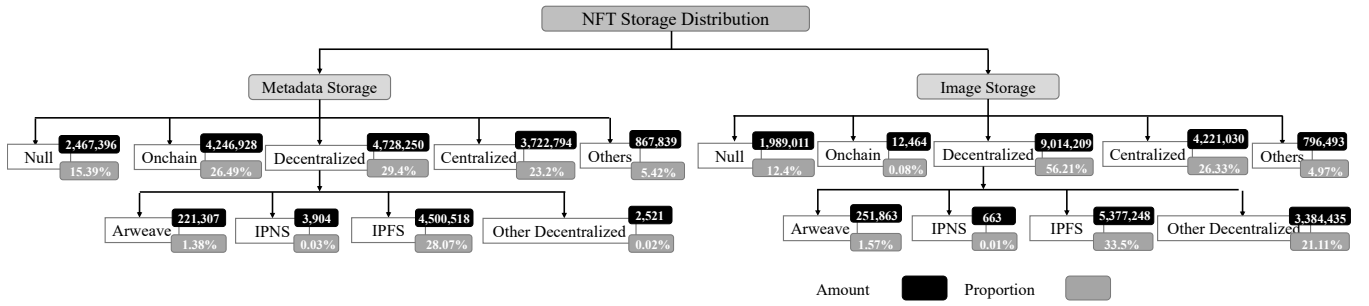


Figure 2: The distribution of NFTs in real-world

The detailed data collection process is described in Appendix A. A statistical overview of this dataset is presented in Table 1.

To develop an objective taxonomy, two authors independently annotated a random sample of 20,000 NFTs following a three-stage open coding procedure [9], achieving a final consensus on the classification schema. The detailed annotation protocol and iteration process are described in Appendix B.

Based on this schema, we classified the entire dataset into distinct categories. Specifically, URLs starting with *data:* or *0x* are labeled as **Onchain**, while invalid endpoints are **Null**. Off-chain pointers are distinguished into **Centralized** (e.g., cloud servers), **Decentralized** (e.g., IPFS, Arweave), or **Others**.

3.2 NFT Storage Distribution

Figure 2 shows the storage distribution for NFT metadata and images, revealing a clear preference for off-chain solutions.

For metadata, decentralized solutions are the most prevalent with 4,728,250 NFTs (29.48%), primarily driven by IPFS (4,500,518 NFTs, 28.07%). Onchain and Centralized strategies follow, accounting for 26.49% and 23.22%, respectively. Additionally, 15.39% of NFTs had null or inaccessible metadata. Other decentralized solutions like Arweave (1.38%) and IPNS (0.02%) remain minor.

The trend of off-chain storage is even more pronounced for images. Decentralized solutions are used for a commanding 9,014,209 NFTs, representing a 52.21% majority of NFTs. IPFS is also the most-used protocol, storing the images for 5,377,248 NFTs (33.54%). Centralized servers remain a major choice for hosting images, accounting for 4,221,030 NFTs (26.33%). Notably, the "Other Decentralized" category holds a surprisingly large share of images at 3,384,435 NFTs (21.11%). In contrast to off-chain storage, storing the image Onchain is exceptionally rare, with only 12,464 NFTs (a negligible 0.08%) adopting this approach. We attribute this overwhelming preference for off-chain solutions to the prohibitive cost of on-chain storage, as detailed in our cost analysis in Appendix C.

3.3 Price-Storage Correlation

While Section 3.2 reveals a preference for off-chain storage, a deeper economic analysis uncovers a startling paradox regarding which assets are most vulnerable. We believe that high-value assets would adopt the most robust persistence strategies (e.g., On-chain or Arweave). However, by correlating storage strategies with floor prices, we observe the opposite, which we term the "Blue-chip Trap".

As illustrated in Figure 3, storage security inversely correlates with asset price (refer to Appendix D for the detailed statistical data). Low-value assets (<\$1) demonstrate a diverse adoption of storage solutions, with only 20.71% relying on centralized servers. In contrast, the ecosystem's most valuable assets (Blue-chip NFTs valued >\$10k) exhibit an overwhelming dependence on centralized infrastructure, with 74.04% hosted on private servers. This trend indicates that top-tier projects prioritize mutability and performance over permanence, effectively trading long-term security for short-term efficiency. The implications of this trade-off are severe.

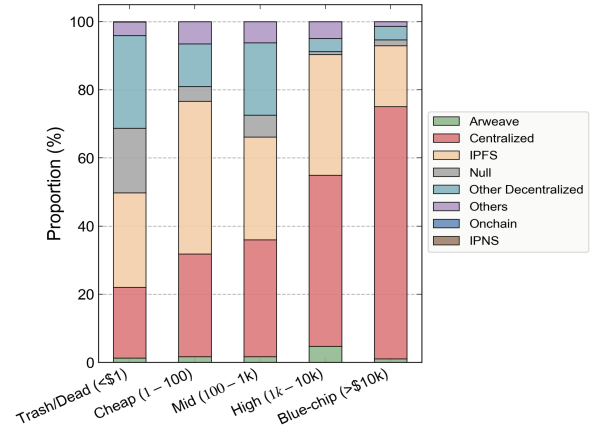


Figure 3: Distribution of NFT storage strategies by asset price

Findings: Our analysis of over 16 million NFTs reveals that the promise of decentralization is largely unfulfilled. We find that only 0.08% of real-world images are stored on-chain. Notably, we uncover a 'Blue-chip Trap': contrary to the expectation that high value ensures adherence to blockchain principles, 74% of high-value NFTs rely on centralized servers, thereby failing to uphold the core promise of decentralized and immutable ownership.

4 RQ2: Defects of NFT Storage Strategies

To categorize the various storage risks, we propose a taxonomy of defects, as outlined in Table 2. This taxonomy organizes eight

Table 2: Taxonomy of NFT Storage Defects

Category	Defect	Definition
Access Failure	D1: Centralized Server Failure	Losing the asset permanently due to the shutdown or failure of its centralized host server
	D2: IPFS Pinning Failure	Losing the asset from the IPFS network because no node has "pinned" it for long-term storage
Tamperability	D3: On-Chain Pointer Redirection	Using a contract function to change the on-chain pointer to a new off-chain location
	D4: IPNS Pointer Abuse	Updating the IPNS record maliciously via private key to make the NFT point to different content
	D5: On-Chain Content Injection	Storing executable code on-chain that can be executed by a frontend
	D6: Unverified Centralized Storage	Modifying the asset on a centralized server without any on-chain transaction
Forgeability	D7: Metadata Duplication	Using the same tokenURI to duplicate metadata
	D8: Image Duplication	Using the same imageURL to duplicate image

specific defects into three categories based on their consequences: access failure, tamperability, and forgeability. In the following sections, we analyze the mechanism and prevalence of each defect in the real world. For the formal definitions and mathematical notations of these defects, please refer to Appendix E.

4.1 Access Failure

Access Failure defects are those vulnerabilities that result in the permanent loss of an NFT's off-chain asset. This category of vulnerabilities can cause a digital asset to become inaccessible, turning the on-chain token into a worthless pointer to a non-existent file.

4.1.1 Centralized Server Failure. Centralized server failure occurs when the centralized server that hosts an NFT (metadata or image), such as a cloud service like AWS, becomes permanently inaccessible. This can be caused by technical malfunctions, service shutdowns, or the project team abandoning its operations. For instance, we identified a representative failure in our dataset within contract `0xa20cf9b0874c3e46b344deae9c2e0c3e1db37d` (Token ID: 4856). While the token remains valid on-chain, its metadata URI points to a centralized server `https://0xhoneyjar.xyz...` that currently returns an "Invalid 404" error, rendering the underlying digital asset permanently inaccessible.

Empirical Analysis Any NFT whose metadata or image is hosted on a centralized server (e.g., AWS, Google Cloud) is directly exposed to this risk. Within our dataset, we identified that 3,722,794 NFTs (23.22%) store their metadata and 4,221,030 NFTs (26.33%) store their images on centralized servers. Upon testing the accessibility of these URLs, we found that the metadata of 457,341 (12.28%) and the images of 486,904 (11.54%) of these centralized links were already inaccessible, returning permanent errors such as 404 (Not Found) or 5xx (Server Error).

4.1.2 IPFS Pinning Failure. The defect of IPFS Pinning Failure stems from a common misconception about the protocol that IPFS does not guarantee permanent storage. IPFS content is only retained as long as it is actively "pinned" by a node; otherwise, it is eventually removed by garbage collection. This defect occurs when the pinning service that an NFT project relies on ceases to maintain the pin for an asset's files, leading to their permanent loss from the network. For instance, we observed a pinning failure in contract `0xf8b37af2b5fe2ce1cc303a8472dedcca0953bb2` (Token

ID: 5777). Its metadata relies on the IPFS hash `QmdQP46GkdonFRnJSXzYhdt125FTfmwjrDctK6ywGyXPQp`, yet accessing it currently returns an Invalid 504 error. This indicates that the underlying file has been garbage-collected from the network because no node is actively pinning it, causing the asset to vanish despite the use of a decentralized protocol.

Empirical Analysis This defect affects NFTs stored on both IPFS and IPNS, as both rely on active pinning for data persistence. Our analysis shows IPFS is a popular choice, we found it is used for 4,500,518 metadata (28.1%) and 5,375,412 images (33.53%), with observed accessibility failure rates of 11.81% (531,428) and 10.13% (544,584), respectively. Although far less common, IPNS was used for 3,904 metadata URLs (0.025%) and 663 image URLs (0.004%), exhibiting a metadata failure rate of 37.68% (1,471) and image failure rate of 4.07% (27). This data demonstrates that IPFS Pinning Failure is a prevalent defect, proving that merely using a decentralized protocol does not guarantee an asset's long-term availability without a pinning strategy.

4.1.3 Overall. To summarize the overall extent of the Access Failure defect, we consolidated the availability statistics for all metadata_urls and image_urls from our dataset. Table 3 presents the comprehensive quantification of inaccessible NFTs.

The data reveal the Access Failure problem. Over 23% of metadata URLs and over 20% of image URLs are effectively broken: either missing entirely or returning an error. Most alarmingly, we found that over 198,342 metadata and 236,872 images suffer from permanent errors such as 404 Not Found, indicating that they are likely lost forever. Empirical data provide evidence that asset vanishing is not a future theoretical risk, but a widespread and ongoing reality in the current NFT ecosystem.

4.2 Tamperability

Tampering Defects allow an NFT to be modified after it has been minted. Unlike Access Failure, which compromises the availability of an asset, these defects can redirect the on-chain token to completely different, or even harmful content, thereby undermining the promise of a permanent and unalterable record.

4.2.1 On-Chain Pointer Redirection. On-Chain Pointer Redirection is a contract-level defect that allows the tokenURI to be altered after an NFT has been minted. This is made possible by privileged

Table 3: Comprehensive Availability Statistics for Metadata and Image URLs

Status Category	Status Codes	Metadata		Image	
		Count	Percentage (%)	Count	Percentage (%)
Valid	200	12,278,875	76.58	12,757,613	79.57
Permanent Client Errors	404, 410	198,342	1.24	236,872	1.48
Permission Errors	403, 401	224,221	1.4	219,135	1.37
Temporary/Server Errors	500, 502, 503	82,716	0.52	20,423	0.13
Rate Limit Errors	429	112,721	0.7	31,900	0.2
Connection/Other Errors	None, etc.	668,936	4.17	778,253	4.85
URL Null	–	2,467,396	15.39	1,989,011	12.4
Total	–	16,033,207	100.00	16,033,207	100.00

functions, such as `setTokenURI()` and `setBaseURI()`, that are included in the smart contract. These functions act as backdoors, granting certain privileged users the ability to redirect the on-chain pointer of an NFT or even an entire collection to a different off-chain asset at any time. This undermines the promise of a permanent and unalterable link between the on-chain token and its off-chain asset, as the asset can be swapped for different or even malicious content without the token holder’s consent.

Case Study To understand the mechanics of On-Chain Pointer Redirection, we selected a representative smart contract, `0xE22a6E2FE923589733f6E1480065A806ce6a99a4`, from our dataset. As detailed in Listing 1, this contract inherits the `Ownable` standard and exposes a privileged function, `setURI()`. By executing the simple instruction `baseURI = _uri;`, the project administrator retains unilateral, centralized control to reroute the metadata pointers for the entire collection instantly. This mechanism renders the initial reliance on decentralized storage irrelevant, as the crucial on-chain link remains mutable and susceptible to rug pulls at the owner’s discretion.

Empirical Analysis We scanned 107,194 contracts, initially flagging 16,713 (15.6%) with mutable functions like `setTokenURI()`. To exclude false positives, we verified contract ownership status: 1,006 utilized custom access controls, while only 68 of the standard contracts had renounced ownership. Consequently, over 99% of flagged collections remain under active control, exposing 5,189,485 NFTs to potential manipulation. This effectively downgrades these assets from trustless property to revocable services dependent on creator benevolence.

```

1 contract ERC1155Contract is ERC1155, Ownable {
2     // ... (state variables omitted) ...
3
4     function setURI(string memory _uri) external
5         onlyOwner
6     {
7         baseURI = _uri; // Mutable state
8     }
9 }

```

Listing 1: Core vulnerability in contract 0xE22a...

4.2.2 IPNS Pointer Abuse. IPNS Pointer Abuse exploits the "decentralized but controllable" nature of the InterPlanetary Name System (IPNS). An IPNS address is a mutable pointer linked to a private key, allowing the key holder to redirect it to new IPFS content at any time. This creates a critical risk of fake security, as the asset is

under the centralized control of a malicious or compromised key holder despite appearing to be on a decentralized network.

Case Study We examine a representative example of this defect in the contract `0xca20888a6f99ef8691e04d7e75f7b5fae8fa7591`. For Token ID 630, the on-chain metadata URI is explicitly stored as `.../ipns/k51qzi...2qc2/630`. Unlike standard IPFS CIDs (which start with `Qm` and are immutable content hashes), the identifier `k51...` represents the hash of a public key within the InterPlanetary Name System (IPNS). This distinction is critical: the URI functions as a dynamic pointer in the Distributed Hash Table, resolving to whatever content hash is currently signed by the corresponding private key. Consequently, the entity holding this key can unilaterally update the underlying metadata, modifying the asset’s name or image, without interacting with the blockchain or leaving any on-chain audit trail.

Empirical Analysis Our systematic scan identified a specific subset of assets relying on the InterPlanetary Name System, comprising 3,904 metadata URIs and 663 image URIs. While these figures represent a small fraction of the total dataset, the security implication is absolute. Unlike implementation flaws, which may vary by contract logic, the mutability of IPNS is an intrinsic architectural feature. Consequently, 100% of these identified assets are susceptible to unilateral off-chain alteration. The holder of the corresponding private key retains the perpetual ability to update the content pointer off-chain. This effectively reintroduces a single point of failure, rendering the assets’ immutability dependent on the key holder’s benevolence rather than cryptographic guarantees.

4.2.3 On-Chain Content Injection. On-Chain Content Injection refers to embedding executable or externally-referenced content into an NFT’s on-chain data (e.g., SVG), so that the payload is activated during rendering by a front-end rather than by the blockchain itself, as illustrated in Figure 4. Typical injection vectors include script-related elements, event-handler attributes (e.g., `onload/onclick`), `javascript:` URLs, or encoded payloads (e.g., nested Base64) that are decoded by the renderer. When rendered in a user’s browser, such content may lead to client-side attacks such as Cross-Site Scripting (XSS), potentially compromising user sessions or platform integrity.

Case Study To validate Defect D5, we deployed a NFT on Seapolia (Contract: `0xb18228cE974CF6b62d9DF5A088D6b29e40900790`, TokenID: 2). We embedded a JavaScript event listener within its

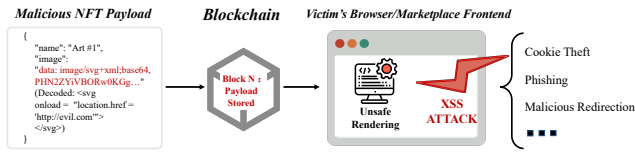


Figure 4: Mechanism of On-Chain Content Injection

fully on-chain SVG data. We confirmed that a simple user interaction (right-click) triggers the payload, immediately redirecting the browser to google.com. This proves that without strict recursive sanitization, immutable blockchain storage can serve as a permanent host for functional Stored XSS vectors.

Empirical Analysis To quantify D5, we analyzed over 4.2 million on-chain data points, comprising both metadata and image data. In the initial scan, we identified 38 explicit instances containing `<script>` tags and `onclick` events. Crucially, we observed that over 2.7 million assets utilized nested Base64 encoding; a second-stage recursive analysis of these artifacts revealed 622 hidden instances containing malicious payloads, including `<script>` tags, 9 `onclick` and 2 `onload` events. In addition, 1,170 assets were found to load external resources. These findings confirm that the blockchain actively hosts persistent executable vectors, refuting the assumption that on-chain implies security.

4.2.4 Unverified Centralized Storage. Unverified Centralized Storage defines a vulnerability where off-chain assets, including both the metadata and the digital media, are hosted on mutable, centralized servers without on-chain integrity verification. Unlike content-addressed storage, centralized storage relies on location-based addressing. This architectural flaw allows server administrators to alter metadata properties or swap the underlying media files without changing the on-chain tokenURI. Crucially, when the metadata itself is mutable, any internal integrity checks (like a hash inside the JSON) can also be falsified, rendering the entire off-chain state untrusted and susceptible to undetectable manipulation.

Case Study Moxie Marlinspike demonstrated this defect with his "At My Whim" NFT [21]. He created an NFT hosted on a centralized server without cryptographic integrity verification, configuring the server to return different images based on the requester's IP. Consequently, the on-chain token rendered as geometric art on OpenSea but appeared as a "poop emoji" in user wallets. This incident proves that without an on-chain integrity anchor, the blockchain functions merely as a static pointer, granting server administrators unchecked authority to silently alter the asset's reality.

Empirical Analysis To mitigate the risk of unauthorized tampering, a standard security practice is to embed a hash value of the media file within the metadata. To evaluate the real-world adoption of this defense, we analyzed 61,417 accessible centralized NFTs sampled from our large-scale inspection. We found that 96% of NFTs completely ignored this mechanism, lacking any verification fields. More critically, even among the 4% NFTs that did include a hash, 94.8% stored the metadata file itself on a mutable centralized server. This configuration offers only weak protection because it fails to establish an immutable root of trust; a malicious administrator can

simply replace the image and overwrite the corresponding hash in the metadata file simultaneously. Consequently, only a negligible 0.2% of the sample achieved effective integrity protection.

4.2.5 Overall. Our analysis exposes a systemic regression: over 5.1 million NFTs remain vulnerable to unilateral tampering. This vulnerability is primarily driven by On-Chain Pointer Redirection, affecting 5,189,485 assets, alongside the widespread reliance on Unverified Centralized Storage. These defects effectively downgrade immutable ownership to a revocable service, making asset persistence dependent entirely on creator benevolence rather than cryptographic guarantees.

4.3 Forgeability

Forgery Defects contain vulnerabilities that exploit the nature of the "segmented" storage strategy. By leveraging the weak binding between an on-chain token and its off-chain asset, these defects make it possible to create fake NFTs that are visually indistinguishable from legitimate ones, or to cause multiple tokens to claim ownership of the same asset. This leads to market confusion, a dilution of value for authentic collections, and a loss of user trust.

4.3.1 Metadata Duplication. Metadata Duplication occurs through the reusing of a single tokenURI across multiple smart contracts. The tokenURI from an NFT in one collection can be copied and used by a token minted from a different contract. This results in two distinct on-chain tokens that both resolve to the identical off-chain metadata file, creating an ambiguous ownership. For instance, we identified a collision between contract `0x2ceb...c175` (Token ID: 937) and contract `0x8f9b...17fc` (Token ID: 30040). Despite being different assets, both resolve to the identical metadata URI (`.../ipfs/QmPmdRJ...GaV`), creating an ambiguity where multiple tokens claim ownership of the exact same off-chain description.

Empirical Analysis We analyzed all instances of reused metadata_urls. Our analysis distinguishes between two forms of metadata reuse: intra-contract and inter-contract duplication. Intra-contract duplication is often an intentional design choice. For example, projects issuing credential-type assets, such as membership passes or event tickets, assign the identical metadata to multiple tokens within a single collection to represent a shared access right.

In contrast, our study focuses on inter-contract duplication to identify potential risks of forgery. We acknowledge that a portion of this cross-contract reuse may stem from benign development practices, such as project teams deploying trial contracts for testing purposes prior to the official launch. However, regardless of the intent, the sheer scale of duplication indicates a widespread lack of unique cryptographic binding. We identified 69,126 groups of metadata_urls shared across distinct contracts. This phenomenon involves 17,196 contracts and affects a total of 300,856 individual NFTs, which accounts for approximately 1.8% of our dataset.

4.3.2 Image Duplication. Image Duplication occurs when distinct tokens resolve to the identical image file, effectively negating the assumption of uniqueness. While intra-contract reuse is often intentional for standardized assets like membership cards or tickets, duplication across different contracts compromises the asset's scarcity. For instance, we identified a collision involving four distinct contracts sharing the same asset. Specifically, contract `0x6310...e606`

(Token ID: 1846) and contract 0x382e...d929 (Token ID: 100001846) both point to the exact same URL (.../...7063ff.png). This demonstrates how assets can be trivially cloned across collections without cryptographic uniqueness.

Empirical Analysis Employing the same methodology used for metadata, we quantified image reuse by clustering distinct NFTs pointing to identical `image_url` endpoints. Notably, this category subsumes Metadata Duplication, as tokens sharing identical metadata inevitably share the same image source. We identified 67,078 groups of duplicate images involving 18,866 contracts and 1,097,235 individual NFTs. This represents 26.9% of our entire dataset, a substantial proportion that highlights a critical problem: unique on-chain identifiers frequently fail to guarantee distinct visual assets.

4.3.3 Overall. We quantified the prevalence of both duplication defects, as shown in Table 4. Our analysis reveals that Image Duplication is a particularly widespread issue, affecting a staggering 1,097,235 NFTs, or 26.9% of the assets in our dataset. Notably, this figure includes not only metadata duplicates, but also intra-contract duplicates. The latter is often an intentional design choice for credential-type NFTs like tickets or membership passes, where multiple tokens are meant to share the same image and metadata.

Table 4: Summary of Forgeability Defects

Defect	Associated Storage	Groups	Affected NFTs (%)
D7	Off-chain storage	69,126	300,856 (1.8%)
D8	Off-chain storage	67,078	1,097,235 (26.9%)

4.4 Summary

This section addresses RQ2 by identifying and analyzing defects inherent in current NFT storage strategies. We established a taxonomy of eight distinct defects categorized into Access Failure, Tamperability, and Forgeability. By combining large-scale empirical analysis with case studies, we validated both the widespread prevalence and the specific exploitation mechanisms of these defects. Ultimately, the weak binding between on-chain tokens and off-chain assets undermines the verifiable uniqueness of a large portion of the NFT ecosystem.

Findings: Our analysis exposes a systemic erosion of NFT value propositions. We confirm that defects are pervasive: over 3.7 million assets are permanently lost, over 5.1 million remain mutable, and over 1 million are compromised by duplication. Collectively, these defects downgrade trustless ownership to a revocable service, rendering asset persistence dependent on administrative discretion.

5 RQ3: Risk Severity of NFT Storage Defects

To systematically evaluate the risk severity of the identified defects, we employ a hybrid assessment framework that integrates qualitative impact analysis with quantitative severity assessment.

To characterize distinctively *where* and *how* defect manifests within the decentralized architecture, we propose a three-dimensional impact classification spanning the Asset, User, and Ecosystem dimensions. Building on this qualitative foundation, we then quantify the technical severity of each defect using the Common Vulnerability Scoring System (CVSS) v4.0 [15]. To further mitigate subjectivity and ensure the robustness of our results, we validated the inter-rater reliability of our scoring process using Cohen’s Kappa [8].

5.1 Impact Assessment Framework

To fully evaluate defects consequences, our framework evaluates the impact in three dimensions, as shown in Table 5.

(1) Asset Dimension: Focuses on the direct harm a defect causes to the fundamental properties of the digital asset. The first is Asset Loss, which occurs when a defect renders the asset permanently inaccessible, making its on-chain token worthless. The second is Integrity Compromise, which refers to cases where the asset’s content is altered or replaced, undermining its promise as an immutable record. Finally, Uniqueness Dilution is the state where the uniqueness of the asset is compromised by the existence of indistinguishable copies or overlapping ownership claims. **(2) User Dimension:** Focuses on the asset holder or potential buyer, assessing the direct and indirect harm a defect can cause to an individual. Economic Loss refers to any scenario where a user suffers a financial loss, such as purchasing a fake NFT or having the value of their asset compromised. Verification Cost addresses the indirect burden placed on users, defined as the additional time and effort required to verify an asset’s authenticity and status due to a defect. **(3) Ecosystem Dimension:** Considers the macro-level consequences of these defects on the entire NFT market. Ambiguous Accountability refers to the difficulty in assigning responsibility for asset loss. This is due to the "segmented" storage structure, which obstructs both dispute resolution and the effective functioning of the market. Trust Erosion captures how the prevalence of a defect can undermine user and investor confidence, damaging the reputation of collections and the market as a whole.

5.2 Severity Assessment

To ensure an objective and standardized quantification of defect severity, we adopted the Common Vulnerability Scoring System (CVSS) v4.0 [15]. This industry-standard framework assesses vulnerabilities based on exploitability metrics and impact metrics. The detailed scoring vectors for each defect are provided in Appendix F. The final severity classifications for all defects are presented in the "Impact level" of Table 5.

Scoring Methodology and Reliability To mitigate subjectivity, the scoring process was conducted by two authors with extensive experience in blockchain security. The process followed a strict two-stage iteration:

- (1) Independent Scoring:** In the first stage, each annotator independently calculated the CVSS Base Score for all eight defects. To evaluate the inter-rater reliability, we calculated Cohen’s Kappa (κ) [8], yielding a coefficient of 0.85. While this value indicates a substantial agreement, it also suggests that perfect alignment was not initially achieved due to the subjective nature of certain metrics.

Table 5: Defect Impact Dimension Analysis

Defects	Asset			User		Ecosystem		Impact level
	Asset	Integrity	Uniqueness	Economic	Verification	Ambiguous	Trust	
Centralized Failure(Sec. 4.1.1)	✓			✓			✓	High
IPFS (Sec. 4.1.2)	✓			✓		✓	✓	High
On-Chain (Sec. 4.2.1)		✓		✓	✓		✓	Medium
IPNS (Sec. 4.2.2)		✓		✓	✓		✓	Medium
Injection (Sec. 4.2.3)		✓		✓	✓	✓	✓	High
Unverified (Sec. 4.2.4)		✓		✓		✓	✓	Medium
Metadata (Sec. 4.3.1)			✓		✓	✓	✓	Medium
Image (Sec. 4.3.2)			✓		✓	✓	✓	Medium

Asset refers to Asset Loss, Integrity refers to Integrity Compromise, Uniqueness refers to Uniqueness Dilution, Economic refers to Economic Loss, Verification refers to Verification Cost, Ambiguous refers to Ambiguous Accountability, Trust refers to Trust Erosion.

- (2) **Consensus Resolution:** In the second stage, we reviewed the specific vectors where discrepancies occurred, such as determining whether the User Interaction metric for the On-Chain Content Injection defect should be classified as Passive or Active. These differences were resolved through discussion until a consensus was reached for every metric.

Based on the final consensus scores, we mapped the defects into three impact levels following standard CVSS qualitative ratings: High (Score ≥ 7.0), Medium (Score 4.0–6.9), and Low (Score < 4.0). Notably, our assessment reveals that all identified defects pose substantial risks, falling exclusively into the High and Medium categories.

High Severity. Defects such as *Centralized Failure*, *IPFS Pinning Failure*, and *On-Chain Content Injection* fall into this category. The former two score high primarily due to their impact on availability, causing permanent asset loss. For *On-Chain Content Injection*, despite requiring user interaction, the severity is driven by the critical potential for wallet compromise or session hijacking, resulting in High ratings for confidentiality and integrity.

Medium Severity. This category encompasses defects like *On-Chain Pointer Redirection*, *IPNS Pointer Abuse*, and *Metadata/Image Duplication*. The scores for *Pointer Redirection* and *IPNS Abuse* are constrained by Privileges Required (PR), as exploitation is limited to the contract owner or private key holder. Interestingly, *Metadata* and *Image Duplication* are also classified as Medium. While they do not compromise the asset's technical availability, their low attack complexity and widespread ecosystem impact (e.g., uniqueness dilution) result in scores that exceed the Low severity threshold.

Findings: Our impact assessment reveals that the fragility of NFT storage is not merely theoretical but poses severe, measurable risks. Quantitatively, all identified defects fall into High or Medium severity categories. Qualitatively, defects affecting the Asset Dimension represent the most critical threats, directly negating the fundamental value proposition of NFTs. Even defects with lower technical severity erode the Ecosystem Dimension by diluting uniqueness and undermining trust.

6 Related Work

NFT persistence is a critical challenge extending beyond on-chain records to off-chain metadata [10]. While on-chain storage is costly, off-chain solutions face significant risks [27]: centralized servers are prone to censorship, while IPFS suffers from centralization trends [4, 29], data availability failures [30], and performance latency [3, 28]. Smart contracts also exhibit vulnerabilities like risky mutable proxies [7, 31].

To address these, researchers propose optimizing on-chain storage via semantic compression such as SemNFT [19] or securing off-chain data through cryptographic commitments such as ERC-7829 [14]. Other solutions enhance off-chain systems directly, for instance, by improving IPFS performance [32] or employing digital watermarking for verification [5].

7 Conclusion

Our large-scale empirical analysis of over 16 million NFTs confirms a significant gap between the narrative of decentralization and the reality of storage strategies. We reveal that merely 0.08% of images are stored on-chain, while high-value assets paradoxically exhibit a Blue-chip Trap by relying heavily on centralized infrastructure. We propose the first taxonomy of storage defects involving access failure, tamperability, and forgeability to demonstrate their widespread prevalence in the ecosystem. Our results show that over 23% of NFTs already suffer from access failures and millions remain vulnerable to unilateral tampering or duplication. Finally, our multi-dimensional assessment quantifies these risks as severe, proving that the foundation of digital ownership is significantly more fragile than commonly perceived.

Acknowledgments

This work is supported in part by the National Key R&D Program of China (No. 2023YFB2703800), the Beijing Advanced Innovation Center for Future Blockchain and Privacy Computing (GJJ-24-024), the National Natural Science Foundation of China (No.62441227, 62472022, U22B2027, and U23A20304), the project U2268202 of the National Natural Science Foundation of China (Joint Fund for Railway Basic Research), and the project J2024S003 of the R&D Center of China State Railway Group Co., Ltd.

References

- [1] Amazon Web Services. 2025. *Amazon AWS Official Site*. Retrieved 2025-07-29 from <https://aws.amazon.com/>
- [2] Arweave. 2025. *Arweave: Permanent Information Storage*. Retrieved 2025-07-29 from <https://arweave.org/>
- [3] Onur Ascigil, Sergi Reñé, Michał Król, George Pavlou, Lixia Zhang, Toru Hasegawa, Yuki Koizumi, and Kentaro Kita. 2019. Towards peer-to-peer content retrieval markets: Enhancing IPFS with ICN. In *Proceedings of the 6th ACM Conference on Information-Centric Networking*. 78–88.
- [4] Leonhard Baldur, Maciej Korczyński, Onur Ascigil, Navin V Keizer, George Pavlou, Björn Scheuermann, and Michał Król. 2023. The cloud strikes back: Investigating the decentralization of IPFS. In *Proceedings of the 2023 ACM on Internet Measurement Conference*. 391–405.
- [5] Flavio Bertini, Alessandro Benetton, and Danilo Montesi. 2025. Distributed Ledger and Text Watermarking for Fine-Grain Provenance Checking of Textual Content. In *Companion Proceedings of the ACM on Web Conference 2025*. 2626–2633.
- [6] Chainstack. 2025. *Chainstack: Web3 Infrastructure Platform*. Retrieved 2025-07-20 from <https://chainstack.com/>
- [7] Shijian Chen, Jiachi Chen, Jiangshan Yu, Xiapu Luo, and Yanlin Wang. 2024. The dark side of NFTs: A large-scale empirical study of wash trading. In *Proceedings of the 15th Asia-Pacific Symposium on Internetware*. 447–456.
- [8] Jacob Cohen. 1960. A coefficient of agreement for nominal scales. *Educational and psychological measurement* 20, 1 (1960), 37–46.
- [9] John W Creswell and Cheryl N Poth. 2016. *Qualitative inquiry and research design: Choosing among five approaches*. Sage publications.
- [10] Dipanjan Das, Priyanka Bose, Nicola Ruaro, Christopher Kruegel, and Giovanni Vigna. 2022. Understanding security issues in the NFT Ecosystem. In *Proceedings of the 2022 ACM SIGSAC conference on computer and communications security*. 667–681.
- [11] DLNews. 2025. *CloneX Collection Disappears*. Retrieved 2025-07-20 from <https://www.dlnews.com/articles/web3/vanishing-clonex-nfts-spark-panic-among-collectors/>
- [12] Ethereum Foundation. 2018. *EIP-1155: Multi Token Standard*. Retrieved 2025-07-20 from <https://eips.ethereum.org/EIPS/eip-1155>
- [13] Ethereum Foundation. 2018. *EIP-721: Non-Fungible Token Standard*. Retrieved 2025-07-20 from <https://eips.ethereum.org/EIPS/eip-721>
- [14] Ethereum Foundation. 2025. *EIP-7829: Ethereum Improvement Proposal*. Retrieved 2025-07-20 from <https://eips.ethereum.org/EIPS/eip-7829>
- [15] FIRST.Org, Inc. 2023. *Common Vulnerability Scoring System v4.0: Specification Document*. Retrieved 2025-12-15 from <https://www.first.org/cvss/v4.0/specification-document>
- [16] Google Cloud. 2025. *Google Cloud Computing Services*. Retrieved 2025-07-29 from <https://cloud.google.com/>
- [17] IPFS. 2025. *IPFS: Powers the Distributed Web*. Retrieved 2025-07-29 from <https://ipfs.tech/>
- [18] Peng Liao, Chaoge Liu, Jie Yin, Zhi Wang, and Xiang Cui. 2024. NFT Security Matrix: Towards Modeling NFT Ecosystem Threat. *Computer Modeling in Engineering & Sciences (CMES)* 139, 3 (2024).
- [19] Lehao Lin, Hong Kang, Xinyao Sun, and Wei Cai. 2024. SemNFT: A Semantically Enhanced Decentralized Middleware for Digital Asset Immortality. In *Proceedings of the 32nd ACM International Conference on Multimedia*. 11051–11059.
- [20] Zuchao Ma, Muhui Jiang, Xiapu Luo, Haoyu Wang, and Yajin Zhou. 2025. Uncovering NFT Domain-Specific Defects on Smart Contract Bytecode. *IEEE Transactions on Dependable and Secure Computing* (2025).
- [21] Moxie Marlinspike. 2022. *My First Impressions of Web3*. Retrieved 2026-01-03 from <https://moxie.org/2022/01/07/web3-first-impressions.html>
- [22] NFT.Storage. 2022. *NFT Research Report: Missing NFTs*. Retrieved 2025-07-20 from <https://blog.nft.storage/posts/2022-04-04-missing-nfts>
- [23] OpenSea. 2025. *OpenSea API Reference*. Retrieved 2025-07-20 from <https://docs.opensea.io/reference/api-overview>
- [24] OpenSea. 2025. *OpenSea: The Largest NFT Marketplace*. Retrieved 2025-07-20 from <https://opensea.io/>
- [25] Precedence Research. 2025. *Non-Fungible Token Market*. Retrieved 2025-07-20 from <https://www.precedenceresearch.com/non-fungible-token-market>
- [26] Rarible. 2025. *Rarible: NFT Marketplace and Protocol*. Retrieved 2025-07-20 from <https://rarible.com/>
- [27] Hamza Salem, Hadi Salloum, Manuel Mazzara, Nursultan Askarbekuly, Leonrad Johard, and Giancarlo Succi. 2025. Hidden Risks: The Centralization of NFT Metadata and What It Means for the Market. In *International Conference on Advanced Information Networking and Applications*. Springer, 154–162.
- [28] Jiajie Shen, Yi Li, Yangfan Zhou, and Xin Wang. 2019. Understanding I/O performance of IPFS storage: a client's perspective. In *Proceedings of the international symposium on quality of service*. 1–10.
- [29] Ruizhe Shi, Ruizhi Cheng, Yuqi Fu, Bo Han, Yue Cheng, and Songqing Chen. 2025. Centralization in the Decentralized Web: Challenges and Opportunities in IPFS Data Management. In *Proceedings of the ACM on Web Conference 2025*. 4068–4076.
- [30] Qin Wang, Rujia Li, Qi Wang, and Shiping Chen. 2021. Non-fungible token (NFT): Overview, evaluation, opportunities and challenges. *arXiv preprint arXiv:2105.07447* (2021).
- [31] Shuo Yang, Jiachi Chen, and Zibin Zheng. 2023. Definition and detection of defects in nft smart contracts. In *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis*. 373–384.
- [32] Wenbin Zhu, Zhaoyan Shen, Mengying Zhao, Dongxiao Yu, and Bingzhe Li. 2025. A Deep Dive into Protocol Design: How to Improve IPFS Performance without Sacrificing Decentralization. In *2025 IEEE 41st International Conference on Data Engineering (ICDE)*. IEEE, 1070–1083.

A Data Collection Methodology

Our NFT data collection involves a three-step methodology. Initially, we retrieve the contract address and tokenID of NFTs from on-chain transactions. In order to ensure every NFT is unique, we then deduplicate these records based on the combination of their contract address and tokenID. Lastly, we utilized the OpenSea API[23] to collect the *metadata_url* and *image_url* of all 16,033,207 NFTs included in our dataset.

A.1 Acquiring NFTs via transactions

We selected Ethereum for our analysis as it represents the largest and most active NFT ecosystem. To ensure that our collection focused on currently active assets, we collected NFTs by analyzing on-chain transaction records, instead of depending on static marketplace lists. Our data collection spanned 15 months, from January 1, 2024, to March 31, 2025.

We obtained transaction logs by utilizing the standard *eth_getLogs* interface via the Chainstack API [6], a service that provides access to Ethereum RPC nodes. As NFTs primarily follow the ERC-721 and ERC-1155 standards, our collected transaction records include events from both protocols. We therefore differentiated the events by inspecting the event signature hash in the *topics[0]* field of each event log: the *Transfer* event corresponds to ERC-721, while the *TransferSingle* and *TransferBatch* events correspond to ERC-1155.

A.2 Extraction and Deduplication

The method for extracting NFT identifiers (contract address and tokenID) varied by token standard. For ERC-721 *Transfer* events, the contract address was retrieved from the log's address field, while the tokenID was decoded from *topics[3]*. However, for ERC-1155 events, the tokenID is encoded in the data field. In the case of *TransferSingle* events, we extract the tokenID from the first 32 bytes of the data field. For more complex *TransferBatch* events, the data field contains offsets to an array of tokenIDs, and we decoded according to the ABI specification to extract each tokenID.

During the initial collection of transaction records, we intentionally retained multiple transfer events for the same NFT to analyze the transaction frequencies. Subsequently, for the convenience of further processing, we duplicated these data. We aggregated records based on the unique combination of a tokenID and contract address, while also calculating the total transaction count and compiling all associated block numbers for each NFT.

A.3 Acquiring Metadata

We used each NFT's contract address and tokenID to call the OpenSea API [23], which provided detailed information including its *metadata_url* and *image_url*.

Table 6: Detailed Count of NFT Storage Strategies by Asset Price Tier

Price Tier	Arweave	Centralized	IPFS	Null	Other Dec.	Others	Onchain	IPNS
Trash/Dead (< \$1)	116,964	2,027,464	2,726,475	1,666,641	2,418,048	361,484	11,800	33
Cheap (\$1-\$100)	91,713	1,371,888	2,174,610	245,272	620,388	332,538	661	624
Mid (\$100-\$1k)	27,405	503,306	326,826	71,104	327,148	84,198	1	5
High (\$1k-\$10k)	14,476	209,755	126,521	3,521	12,987	16,333	2	1
Blue-chip (> \$10k)	1,305	108,617	22,816	2,473	5,864	1,940	0	0

In particular, to distinguish between NFTs and Fungible Tokens (FTs) that follow the ERC-1155 standard, we first made a judgment based on the contract’s ABI of the function *totalSupply()*. For contracts without this function, we made the final determination based on the values of *owners* or *quantity* fields from the NFT information.

A.4 Overview of Collected Data

A data overview is shown in Table 1. Our data pipeline processed a total of 82,289,058 on-chain transactions to identify all potential token transfer events. This initial collection contained 16,538,984 unique token identifiers, which is higher than the final NFT count because it includes both NFTs and FTs that utilize the ERC-1155 standard. After filtering out FTs (as described in Appendix A.2), the final, deduplicated count is 16,033,207 NFTs, originating from 107,194 unique smart contracts. The counts for *metadata_url* (13,565,811) and *image_url* (14,044,196) are lower than the total NFTs, because a portion of NFTs had null values for these fields, as analyzed in Section 3.2.

B Storage Classification Methodology

To develop an objective classification of NFT storage strategies, we employed the widely adopted open procedure, conducted by two annotators (authors of the paper) with extensive blockchain experience. The iterations are as follows:

Iteration 1: We randomly selected 10,000 samples from the dataset. Each annotator independently analyzed storage patterns and assigned descriptive labels based on *metadata_url* and *image_url*. Discrepancies were then discussed and reconciled, resulting in a preliminary classification schema with initial categories and draft definitions. **Iteration 2:** To validate and refine the schema, another 10,000 samples were independently labeled by both annotators. Remaining disagreements were resolved through discussion, leading to minor revisions of the classification and labeling strategy. **Iteration 3:** Once the classification schema was finalized and validated through the manual iterative process, we implemented it as a deterministic Python script. This automated script was then executed on the entire dataset of 16.5 million NFTs.

C Storage Cost Analysis

The clear preference for off-chain storage strategies, despite the promise of on-chain decentralization, prompts an important question: Why have these specific storage strategies been so widely adopted? To understand the driving factor behind this, we investigated the expense of different storage solutions. Due to the size limitations of storing data on the Ethereum, our on-chain cost

analysis is based on a representative data size of 20 KB. We then compared the cost of storing data across four primary locations (on-chain, Arweave, IPFS, and centralized cloud services), with the results summarized in Table 7.

The data reveals the disparity: storing data directly on Ethereum is orders of magnitude more expensive than any off-chain alternative. Notably, the on-chain expense is based on transaction gas fees and is highly volatile. For our calculation, we used gas price of 0.96 Gwei (9.6×10^{-10} ETH) and an ETH price of \$4,100 USD. Based on these, storing a 20 KB file on-chain costs 0.003963 ETH, which is equivalent to approximately 16.2 USD.

Table 7: Expense Comparison of Different Storage Locations

Location	Size	Expense	Performance
Ethereum	20 KB	16.2 USD	Slow
Arweave	1.6 GB	25 USD	Medium
IPFS	1 TB	20 USD/month	Fast
Amazon S3	10 GB	0.23 USD/month	Fast

D Detailed Distribution of Storage Strategies by Asset Price

To provide a more granular view, Table 6 details the absolute number of NFTs for each storage strategy within each price category. Note that to define these USD-based tiers, we converted historical transaction values using the exchange rate of 1 ETH $\approx$ \$4,100 observed during the study. This detailed breakdown further corroborates our finding that high-value assets rely disproportionately on centralized infrastructure.

E Formal Definition

In the following sections, we provide a detailed definition for each defect, using the notation N to denote an NFT, M and I represent its respective metadata and image assets.

E.1 Centralized Server Failure

Formal Definition We define a function $Host(X)$ that returns the host server of a given resource X . We assume assets are hosted on a centralized server, denoted as S_c , such that $Host(M) = S_c$ and $Host(I) = S_c$. Furthermore, we define a function $Status(S)$ that returns the server’s state, where $Status(S) \in \{Available, Unavailable\}$, and use the symbol $\perp$ to denote a permanently inaccessible resource.

Table 8: CVSS v4.0 Scoring Specifications for Each Defect

Defect Name	CVSS Base Metrics	Result
Access Failure (High Severity)		
Centralized Server Failure	AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/ VA:H /SC:N/SI:N/SA:N	High
IPFS Pinning Failure	AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/ VA:H /SC:N/SI:N/SA:N	High
Tamperability (Mixed Severity)		
On-Chain Pointer Redirection	AV:N/AC:L/AT:N/ PR:H /UI:N/VC:N/ VI:H /VA:N/SC:N/SI:N/SA:N	Medium
IPNS Pointer Abuse	AV:N/AC:L/AT:N/ PR:H /UI:N/VC:N/ VI:H /VA:N/SC:N/SI:N/SA:N	Medium
On-Chain Content Injection	AV:N/AC:L/ AT:P /PR:N/ UI:P / VC:L / VI:L /VA:N/ SC:H / SI:H / SA:H	High
Unverified Centralized Storage	AV:N/AC:L/AT:N/ PR:H /UI:N/VC:N/ VI:H /VA:N/SC:N/SI:N/SA:N	Medium
Forgeability (Medium Severity)		
Metadata Duplication	AV:N/AC:L/AT:N/ PR:L /UI:N/VC:N/ VI:L /VA:N/SC:N/SI:N/SA:N	Medium
Image Duplication	AV:N/AC:L/AT:N/ PR:L /UI:N/VC:N/ VI:L /VA:N/SC:N/SI:N/SA:N	Medium

Highlight Key: Bold metrics indicate primary drivers of the severity score. **AT:** Attack Requirements, **SC/SI/SA:** Subsequent System Confidentiality/Integrity/Availability.

The trigger condition for Defect D1 and its direct consequence can be described by the following logical implication:

$$Status(S_c) = \text{Unavailable} \implies (M = \perp \vee I = \perp)$$

E.2 IPFS Pinning Failure

Formal Definition To formalize this defect, we note that the availability of an asset set A on the IPFS network depends on a "pinning" mechanism. If a file is not actively pinned, it can be removed by the network, causing the asset's status, $Status(A)$, to become Unavailable.

The defect is formalized as follows:

$$Status(A) = \text{Unavailable} \implies A = \perp$$

E.3 On-Chain Pointer Redirection

Formal Definition Let $C(N)$ be the bytecode of the smart contract for an NFT N . We define a set of mutable functions $F_{mutable}$, containing any function signature (e.g., $setTokenURI()$, $setBaseURI()$) that can alter the tokenURI returned for N at a given time t , denoted as $URI(N, t)$.

D3 is present in the contract $C(N)$ if it contains any function from the set $F_{mutable}$. The consequence of the defect is that the tokenURI can be changed after the minting time t_{mint} , formalized as:

$$\begin{aligned} \exists f \in F_{mutable} : f \in C(N) \implies \\ \exists t > t_{mint} : URI(N, t) \neq URI(N, t_{mint}) \end{aligned}$$

E.4 IPNS Pointer Abuse

Formal Definition To formalize this defect, we consider an asset's tokenURI is an IPNS address, denoted as URI_{ipns} . This IPNS address is linked to a private key, sk . We define a function $Resolve(URI_{ipns}, t)$ that returns the specific IPFS content hash (CID) to which the IPNS address points at a given time t . The holder of the private key sk can execute an *Update* operation at any time.

The D4 is triggered when the holder of sk executes the *Update* operation at a time t_2 after an initial time t_1 . The consequence is a change in the resolved content, formalized as:

$$\begin{aligned} Update(sk, t_2) \implies \\ (Resolve(URI_{ipns}, t_2) \neq Resolve(URI_{ipns}, t_1)) \end{aligned}$$

E.5 On-Chain Content Injection

Formal Definition Let A be an asset set that is stored fully on-chain, a condition we denote as $IsOnChain(A)$. We define a malicious script as s . The defect is present if the data of the asset A contains such a script, i.e., $s \in A$. We also define a front-end application, App_{FE} (e.g., an NFT marketplace), and an operation $Render(App_{FE}, A)$ that represents the application rendering the on-chain asset.

The defect is triggered when the front-end application renders the asset. The consequence is the execution of the embedded malicious script, denoted as $Execute(s)$, which is formalized as:

$$(s \in A) \wedge Render(App_{FE}, A) \implies Execute(s)$$

E.6 Unverified Centralized Storage

Formal Definition We consider an asset set A_{t_1} hosted on a centralized server S_c and pointed to by a static tokenURI denoted as URI_{static} . The defect is triggered when an attacker performs a Tamper action, directly modifying the asset A_{t_1} on the server S_c . The consequence is that the same tokenURI now resolves to a new and different asset, A'_{t_2} , at a later time t_2 , as formalized:

$$Tamper(S_c, A_{t_1}) \implies (Resolve(URI_{static}) = A'_{t_2} \wedge A'_{t_2} \neq A_{t_1})$$

E.7 Metadata Duplication

Formal Definition The defect of Metadata Duplication is defined as a state where an NFT N_1 from a smart contract C_1 and another NFT N_2 from a distinct smart contract C_2 (where $C_1 \neq C_2$) share the identical tokenURI (i.e., $URI(N_1) = URI(N_2)$).

E.8 Image Duplication

Formal Definition The defect of Image Duplication is defined as a state where at least two distinct NFTs, N_1 and N_2 , resolve to the identical image (i.e., $\text{ResolveImage}(N_1) = \text{ResolveImage}(N_2)$).

F CVSS Scoring Specifications for NFT Storage Defects

This section details the complete scoring specifications used in our severity assessment. To ensure a rigorous and reproducible evaluation, we utilized the **CVSS v4.0 Base Metric Group**, which evaluates the intrinsic qualities of a vulnerability that remain constant over time and between user environments.

In determining the vectors, we establish the baseline assumption of an external attacker with no special access (PR:N). Deviations from this baseline (e.g., PR:H or PR:L) were applied only when the defect requires administrative control, such as possessing a private key, server credentials, or contract ownership. Notably, regarding User Interaction (UI), *On-Chain Content Injection* represents the sole exception requiring UI:P (Passive), as the vulnerability is triggered only when a victim renders the malicious asset. This metric was a primary subject of the inter-rater discussion described in Section 5.2, where initial divergences were resolved to accurately reflect the passive nature of the interaction. Table 8 explicitly lists the consensus vector strings derived from this process.